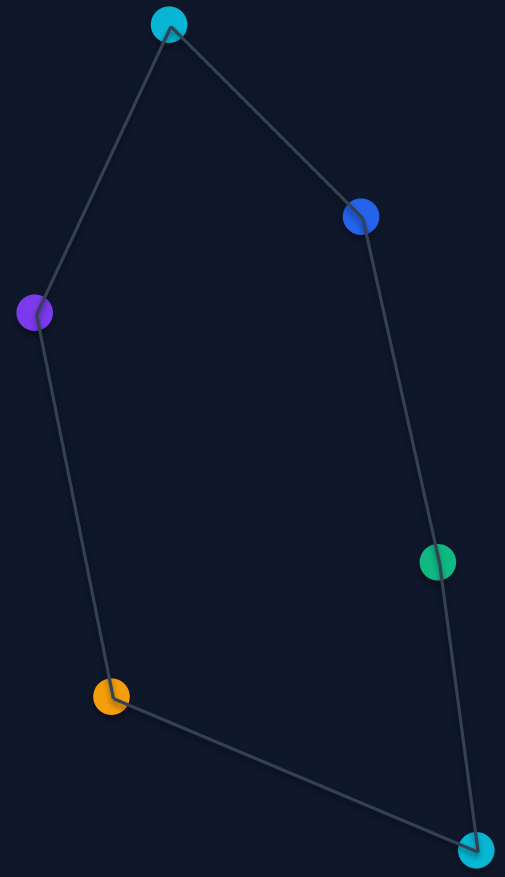
產業科技實務

Week 2

AWS 全球基礎設施與共擔責任模型



2026 / 09 / 17

企業為什麼走向公有雲？

從「買設備」轉向「取得能力」

地端機房

容量預估容易失準
硬體折舊與汰換
電力 / 空調 / 機房維護
跨國部署成本與延遲

公有雲

彈性擴展
Pay-as-you-go
全球基礎設施即取即用
數分鐘內建立跨區架構

CAPEX → OPEX

AWS 全球基礎設施概觀

規模不是目的；規模帶來的是選擇、韌性與距離

39	123	700+	1
Geographic Regions	Availability Zones	CloudFront / PoPs*	Private global backbone

AWS 全球私有網路：Region ↔ AZ ↔ Edge 之間，以專用網路與冗餘連線支撐效能與韌性。

什麼是 AWS Region？

一個「地理位置 + 隔離邊界」的運算與資料服務集合

Region

全球各地的獨立地理位置。
每個 Region 由多個彼此隔離的 Availability Zones 組成。

為什麼要隔離？

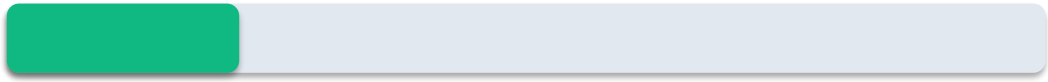
降低區域性故障的連鎖影響。
企業可選擇在哪裡存放資料、部署服務。

Region ≠ 一棟資料中心

網路延遲：物理世界仍然存在

雲端不能消除距離；只能讓距離更有效率

台北 ↔ 東京



約數十 ms

台北 ↔ 美西



約百餘 ms

跨洋 / 跨洲



更高 RTT

金融交易・即時 API・遊戲對戰：延遲會直接變成使用者體驗與商業成本。

服務支援度：不是每個 Region 都一樣

「Region 存在」≠「所有 AWS 服務都存在」

先行 Region

新服務常先在少數大型 Region 推出，再逐步擴散。
因此企業不能只看地理距離。

查什麼？

Region Table
Service availability
Quota / instance family
跨 Region 功能限制

架構選型前：確認「你要的服務」+「你要的 Region」是否同時成立。

不同 Region 的成本差異

價格不是單一數字，而是整體 TCO

N. Virginia

成熟 / 大型 Region

EC2：instance / OS / tenancy
S3：storage / request / transfer

Tokyo

亞洲低延遲

EC2：instance / OS / tenancy
S3：storage / request / transfer

Singapore

區域樞紐

EC2：instance / OS / tenancy
S3：storage / request / transfer

土地、能源、稅務、供應鏈與服務成熟度，都可能反映在價格結構中。

特殊區域：GovCloud 與主權雲

當「資料在哪裡」進一步變成「誰能控制」

AWS GovCloud (US)

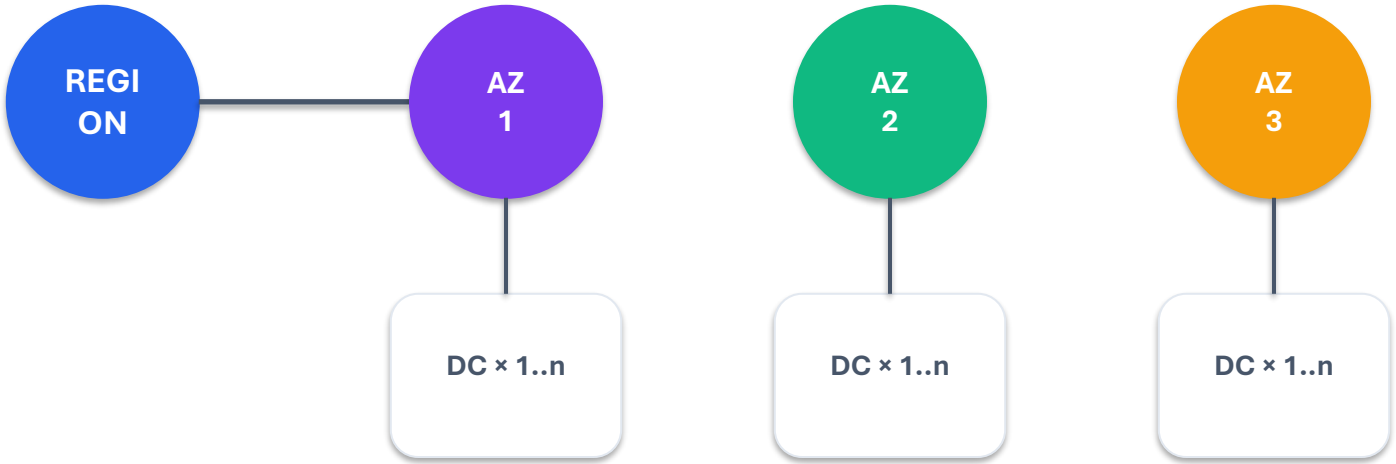
面向美國政府與受監管工作負載的獨立 AWS Regions。
重點：合規、隔離、受限人員與資料處理要求。

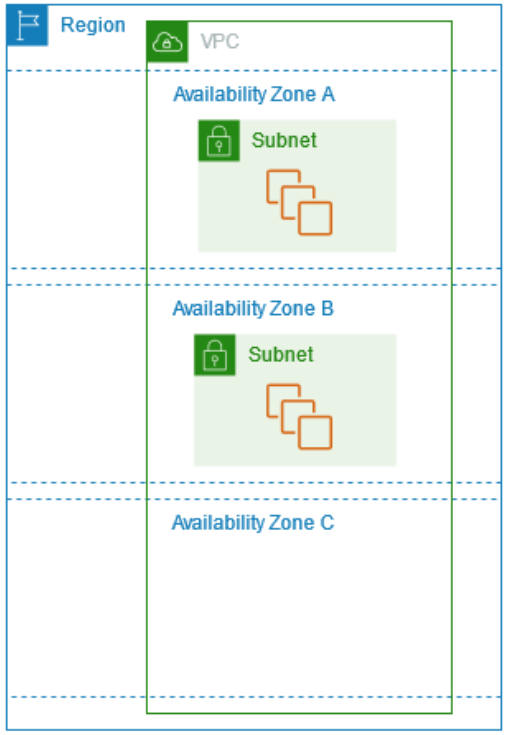
European Sovereign Cloud

獨立的歐洲主權雲環境，位於 EU 境內，聚焦資料主權與營運控制。

什麼是 Availability Zone ?

AZ 不是「一間機房」





每個 AZ：一個或多個具備冗餘電力、網路與連線的獨立資料中心。

AZ 之間的高速專屬光纖連線

Multi-AZ 的前提：隔離，但又要能高速協作



高頻寬 + 低延遲 + 冗餘網路

讓跨 AZ 負載平衡、複寫與 Failover 成為可行的企業架構模式。

AZ Name ≠ AZ ID

為什麼不同 AWS 帳號的「1a」不一定是同一個實體 AZ？

帳號 A

ap-northeast-1a
→ 實體 AZ ID：apne1-az1

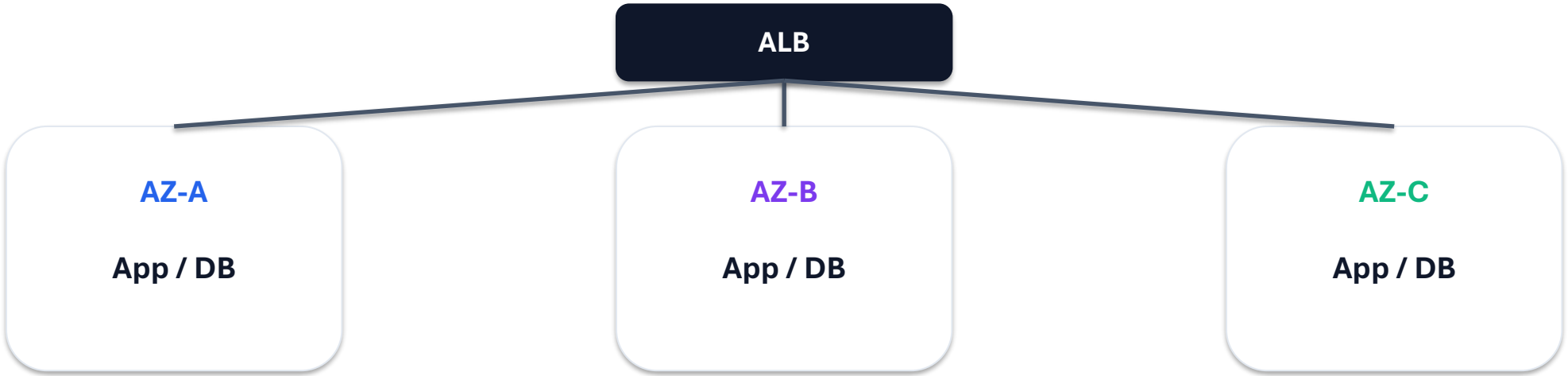
帳號 B

ap-northeast-1a
→ 可能對應另一個 AZ ID

跨帳號做資源對齊時：看 AZ ID，不要只看 AZ Name。

多可用區高可用架構

Design for Failure：假設任何單一元件都可能壞



Single-AZ：故障 = 服務中斷
Multi-AZ：故障 → Failover → 服務持續

AWS 台灣在地佈局：從 Edge 到 Region

台灣的雲端基礎設施已從「邊緣接入」走向完整 Region

0s

2010s

Direct Connect / Edge

企業專線與邊緣服務

20

2020

Taipei Local Zone

台北低延遲運算

5+

2025+

Taipei Region

ap-east-2：3 AZ

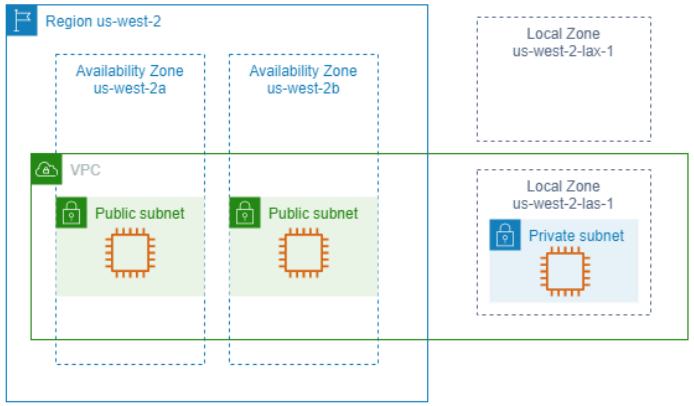
對台灣企業：在地資料、低延遲與高可用架構的選項更完整。

超低延遲：Local Zones & Outposts

Region 不一定是唯一答案

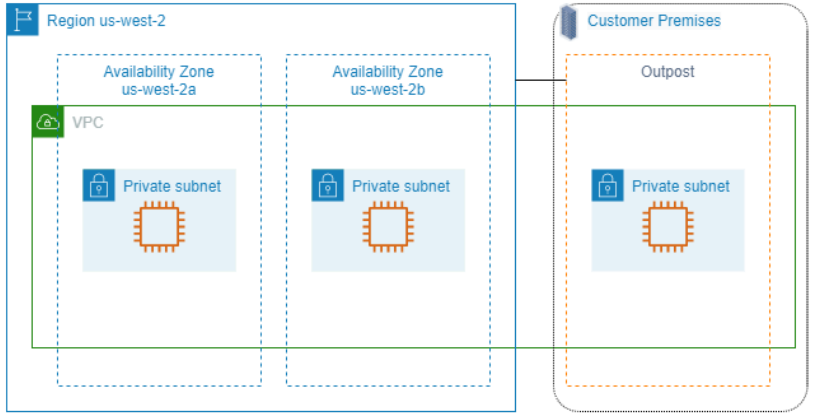
Local Zones

把部分運算 / 儲存能力延伸到特定都會區。
適合需要更靠近終端使用者的工作負載。



AWS Outposts

在客戶自己的機房部署 AWS 基礎設施與 API。
適合低延遲、資料留置或混合雲需求。



Edge Location 與 PoP 是什麼？

把服務能力往使用者「最後一哩」推



Edge：就近快取 / 終止連線 / 加速
Region：完整運算、資料庫與核心服務

邊緣節點的核心服務：Amazon CloudFront

CDN 的核心：讓內容離使用者更近

Cache

圖片、CSS、JS、影片等可快取內容
→ 減少 Origin 請求

Dynamic

API / 動態內容
→ 連線與路由最佳化

Security

與 WAF / Shield 整合
→ 把攻擊擋在 Edge

User → CloudFront → Origin

AWS 私有骨幹與 Global Accelerator

公網不是唯一的路

一般 Internet

BGP 多跳路由
壅塞與路由變動
路徑不可完全掌控

AWS Global Accelerator

Anycast IP
就近進入 AWS Edge
再走 AWS 全球網路骨幹

重點：不是「讓光速變快」，而是縮短與穩定可控的網路路徑。

雲端安全誰負責？

Shared Responsibility Model：安全不是「買了雲」就自動完成。

共擔責任模型：兩句話先記住

Security OF the Cloud

AWS 負責
實體、硬體、網路、虛擬化與基礎設施安全

Security IN the Cloud

客戶負責
資料、身分、設定、應用程式與依服務型態而定的 OS / 網路

Shared ≠ Shared equally

Security OF the Cloud：AWS 的防護範圍

Physical

資料中心、門禁、監控

Hardware

伺服器、儲存、網路設備

Virtualization

Hypervisor / Nitro

Lifecycle

硬體維護與汰換

你不需要管理 AWS 機房裡的硬碟螺絲；但你必須管理自己的資料與設定。

Security IN the Cloud：客戶的防護範圍

Data

分類、加密、備份

Identity

IAM / MFA / RBAC

OS / App

Patch / 漏洞 / 程式碼

Network

SG / NACL / Route

雲端資安最常見的問題，不一定是 AWS 壞了，而是「我們設定錯了」。

IaaS vs. PaaS vs. Serverless / SaaS

託管程度越高 → 客戶維運負擔越低

IaaS

EC2

客戶管理較多

PaaS / Managed

RDS

AWS 接管更多底層

Serverless

Lambda / S3

不管理底層伺服器

抽象化 ↑　客戶管理 ↓　自由度與責任重新分配

Amazon EC2：共擔責任邊界

AWS

實體伺服器
電源 / 網路
Hypervisor / Nitro
底層基礎設施

客戶

OS 選型與 Patch
EDR / 防毒
Port / Security Group
Application Security

Amazon RDS：AWS 接管更多底層

AWS 接管

底層主機
OS 維運
DB Engine 安裝 / 維護
自動備份等託管能力

客戶仍負責

DB 帳號與權限
Schema / SQL
資料分類與加密選擇
網路存取控制

Lambda & S3：你不用管理伺服器，但仍要管理安全

不用管

實體伺服器
OS Patch
Hypervisor
容量規劃

仍要管

程式碼
IAM
Bucket Policy
資料與加密

常見誤區

Serverless ≠ Securityless
託管服務降低的是基礎設施負擔，不是所有資安責任。

三種模式：責任邊界一覽

維度	EC2	RDS	Lambda / S3
Physical	AWS	AWS	AWS
Virtualization	AWS	AWS	AWS
OS	客戶	AWS	AWS
Network config	客戶	共同	客戶
Identity	客戶	共同	客戶
Application	客戶	共同	客戶
Customer data	客戶	共同	客戶

資料加密與金鑰自主

AWS 提供工具；企業決定資料保護策略

AWS 提供

KMS
CloudHSM
Encryption at Rest / Transit 能力

企業決策

是否加密
金鑰輪換
誰能使用金鑰
敏感欄位如何遮蔽

IAM：身分就是新的周界

Least Privilege 比「方便」更重要

❌ AdministratorAccess

→ 方便，但爆炸半徑巨大

✓ 精確 Action + Resource

→ 只給完成工作所需的最小權限

MFA · Role · Policy · Least Privilege

VPC：雲端的虛擬邊界

AWS 提供

虛擬網路底座
VPC / Subnet / Routing primitives

客戶配置

Subnet
Route Table
NAT Gateway
Security Group / NACL

Security Group = Stateful Firewall

OS 安全與 Patch Management

EC2 上的 Linux / Windows，Patch 仍然是你的責任

問題

Zero-Day 發布後
誰要決定「何時 Patch」？
誰要驗證 Patch 後服務沒壞？

AWS 輔助

Systems Manager
Patch Manager
自動化排程與合規檢查

備份、Failover 與業務連續性

AWS 有高可用基礎設施，不代表你的資料「不會被刪掉」

RTO

Recovery Time Objective
多久要恢復？

RPO

Recovery Point Objective
最多可以遺失多少資料？

客戶架構責任

Backup / Restore
Failover
DR Runbook
演練與驗證

第三方稽核與合規認證

AWS 如何證明 Security OF the Cloud ?

ISO 27001

資訊安全管理

SOC 1 / 2 / 3

控制與稽核報告

PCI DSS

支付卡產業標準

合規不是「AWS 全包」；客戶仍需證明自己的應用與流程符合要求。

合規神器：AWS Artifact

企業資安與稽核團隊查 AWS 報告的重要入口

你可以取得

AWS 官方合規報告
SOC 報告
ISO 相關文件
特定合規協議與文件

使用方式

把 AWS 的「基礎設施控制」納入你的稽核證據，再補上自己的 Customer-Specific Controls。

企業稽核：哪些控制可以繼承？

Inherited	AWS 實體安全 / 機房控制
Shared	Patch、時間同步等共同控制
Customer-specific	應用邏輯、員工權限、資料治理

雲端滲透測試：規範與邊界

可以測，但不是「想打哪裡都可以」

原則

針對允許的 AWS 服務進行測試時，依現行 AWS 政策執行。
禁止破壞底層基礎設施或影響其他客戶。

實務提醒

測試前確認：
Scope / Target / Rate Limit
帳號隔離 / 事件應變 / 供應商規範

請以 AWS Penetration Testing Policy 最新版本為準

S3 權限公開：誰的責任？

「Bucket 在 AWS」≠「AWS 會替你決定誰能讀」

錯誤設定

S3 Bucket
Public Read



資料外洩

責任判定：Security IN the Cloud
AWS 可提供 Block Public Access 等防呆機制，但客戶仍須正確配置。

API Key 外洩 → GPU 挖礦

典型攻擊鏈：Credential Leak → Resource Abuse



防禦：IAM Role · Secrets Manager · Git-secrets · MFA · Cost Anomaly Detection

AWS 原生安全防護矩陣

不同工具，處理不同階段

GuardDuty

威脅偵測

Inspector

弱點掃描

Security Hub

集中告警

CloudTrail

API 稽核

Detect → Assess → Centralize → Audit

Web 應用防護：WAF vs. Shield

AWS WAF

Layer 7
SQL Injection / XSS
HTTP request filtering

AWS Shield

Layer 3 / 4
DDoS protection
Standard / Advanced

WAF：理解「請求內容」　|　Shield：承受「流量攻擊」

High Availability vs. Disaster Recovery

「不中斷」與「災後恢復」是兩種不同問題

HA

目標：故障時持續服務
常見：Multi-AZ
時間尺度：秒 ~ 分鐘

DR

目標：重大災難後恢復
常見：Cross-Region
時間尺度：分鐘 ~ 小時以上

HA 解決「壞一台還能不能跑」；DR 解決「整個區域沒了怎麼辦」。

跨 Region 災難復原四大策略

Backup & Restore

成本最低 / RTO、RPO 較長

Pilot Light

核心元件異地待命

Warm Standby

縮小版環境持續運行

Active-Active

最高成本 / 近乎即時服務

成本 ↑ ←——————→ **恢復速度 / 可用性 ↑**

Root User：企業雲端管理的最高禁忌

Root 的特性

完整帳號控制權
不能用 IAM Policy 限制其本身

最佳實務

啟用 MFA
避免 / 刪除 Root Access Key
日常維運不用 Root

Root = Break Glass Account

為什麼企業不該把所有東西塞進一個 AWS Account？

Blast Radius

一個帳號出事，影響面過大

Billing

難以按團隊 / 系統分帳

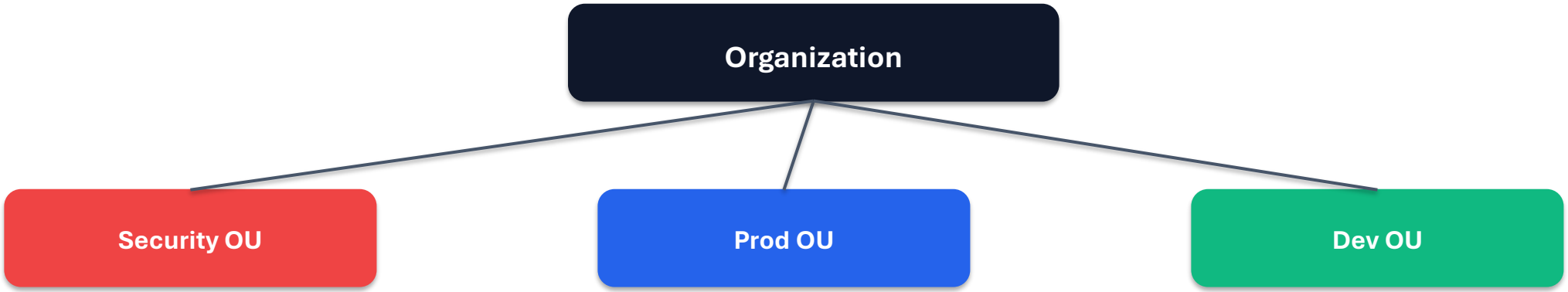
Governance

權限與政策難集中管理

Multi-Account = 隔離風險 + 清楚治理 + 更容易擴張

AWS Organizations & Control Tower

把「單一帳號管理」提升到「組織級治理」



SCP = 組織級 Guardrail
Control Tower = 標準化 Landing Zone 與治理

SCP 實戰：用政策把「不該發生的事」先禁止

範例 1

限制允許使用的 AWS Regions
→ 避免資料落到未核准地區

範例 2

禁止關閉或破壞 CloudTrail
→ 保留組織級稽核能力

SCP 是「上限」，不是「授權」：它不會取代 IAM Permission。

雲端稽核的黑盒子：AWS CloudTrail

回答：誰、何時、從哪裡、呼叫了什麼 API？

WHO

誰做的？

WHEN

何時？

WHERE

來源 IP / Region

WHAT

呼叫哪個 API？

Incident Response：先看證據，再做判斷。

資源狀態快照：AWS Config

持續知道「現在的資源設定是不是符合政策」

持續記錄

Resource configuration
Configuration history
Relationship

合規規則

S3 是否加密？
EC2 是否有正確 Tag？
Security Group 是否過度開放？

CloudTrail：誰動了什麼？ | **Config：現在資源長什麼樣？**

企業雲端治理：把最佳實務變成預設值

成熟的治理不是靠「提醒大家小心」

Identity

MFA / Least Privilege

Network

標準 VPC / SG

Logging

CloudTrail / Config

Cost

Budget / Anomaly

Guardrails > 人肉檢查

企業架構選型：先問 5 個問題

1. 資料能放哪裡？
2. 使用者在哪裡？
3. 需要哪些 AWS 服務？
4. 故障時要撐多久？
5. 預算與 TCO 是多少？

Compliance → Latency → Availability → Service → Cost

一個架構沒有「最好」，只有「最適合」

成本

↑ Multi-AZ / Multi-Region

可用性

↑ Redundancy

延遲

↓ 距離 / Edge

合規

↑ 隔離 / Governance

工程師的價值：把技術選項轉成商業取捨。